

Sikkerhet og abstraksjonsnivå

Lovpålagte rammer og krav

GDPR (General Data Protection Regulation) er EUs personvernforordning som beskytter personopplysninger.

- Personopplysninger skal behandles **lovlig, sikkert og åpent**.
- Man skal bare samle inn **opplysninger som er nødvendige**.
- Personer har rett til blant annet **innsyn, retting og sletting** av egne opplysninger.
- Virksomheter må beskytte data mot **misbruk, tap og uautorisert tilgang**.

GDPR artikkel 25 og 32

GDPR artikkel 25 – innebygd personvern og personvern som standard: Virksomheten skal bygge personvern inn i systemer og løsninger fra starten. Standardinnstillingene skal beskytte personopplysninger og bare samle inn/behandle det som er nødvendig.

GDPR artikkel 32 – sikkerhet ved behandling: Virksomheten skal ha **passende tekniske og organisatoriske sikkerhetstiltak** ut fra risikoen, for eksempel tilgangskontroll, kryptering, sikkerhetskopiering og rutiner for å håndtere sikkerhetshendelser.

3.7 Personvern og trusselmodellering

Viken fylkeskommune vil innføre et nytt digitalt system for gjennomføring av avsluttende skriftlig eksamen for elever i videregående skole.

En av løsningene de vurderer er en sky-tjeneste fra en ekstern IT-leverandør, tilgjengelig for elever, sensorer og skoleadministrasjonen som en web-applikasjon. Både lagring av data og kjøring av applikasjonen skjer på leverandørens datautstyr som står fysisk plassert i et EU-land, mens selve eksamen gjennomføres i en nettleser på skolenes datamaskiner i skolenes lokaler.

Eksamenssystemet må inneholde nok informasjon til å entydig identifisere elever og sensorer (personnummer, navn, kandidatnummer), elevenes besvarelser, samt sensors begrunnelse og karakter for hver enkelt eksamensbesvarelse vedkommende sensurerer.

Eksamensoppgave

Oppgave A)

Fylkeskommunen må vurdere krav til *personopplysningsvern* (GDPR), og du skal hjelpe dem på vei. Vurder følgende utsagn, og kryss av de som er korrekte med utgangspunkt i bruken av et eksamenssystem som beskrevet over:

Velg ett eller flere alternativer:

- ☐ Fylkeskommunen kan se bort fra personopplysningsloven for behandling av personopplysninger, siden det er helt nødvendig å behandler data om elever for å gjennomføre eksamen.
- ☐ Elevene har rett til innsyn i hvilke personopplysninger som er lagret om dem.
- ☐ Fylkeskommunen er ikke juridisk ansvarlig for at opplysninger om elever behandles i samsvar med personopplysningsloven, da eksamenssystemet i sin helhet er levert av et eksternt firma.
- ☐ Personopplysningsloven stiller krav til informasjonssikkerhet; Konfidensialitet, integritet og tilgjengelighet.

Oppgave A)

Fylkeskommunen må vurdere krav til *personopplysningsvern* (GDPR), og du skal hjelpe dem på vei. Vurder følgende utsagn, og kryss av de som er korrekte med utgangspunkt i bruken av et eksamenssystem som beskrevet over:

Velg ett eller flere alternativer:

- ☐ Fylkeskommunen kan se bort fra personopplysningsloven for behandling av personopplysninger, siden det er helt nødvendig å behandle data om elever for å gjennomføre eksamen.
- ☒ Elevene har rett til innsyn i hvilke personopplysninger som er lagret om dem.
- ☐ Fylkeskommunen er ikke juridisk ansvarlig for at opplysninger om elever behandles i samsvar med personopplysningsloven, da eksamenssystemet i sin helhet er levert av et eksternt firma.
- ☒ Personopplysningsloven stiller krav til informasjonssikkerhet; Konfidensialitet, integritet og tilgjengelighet.



Sikkerhet gjennom hele utviklingsfasen

De syv fasene:

- **Opplæring** – lære om sikkerhet og personvern.
- **Krav** – definere krav til systemet.
- **Design** – planlegge løsningen med personvern og sikkerhet.
- **Koding** – utvikle systemet etter kravene.
- **Test** – kontrollere at systemet fungerer og er sikkert.
- **Produksjonssetting** – ta systemet i bruk.
- **Forvaltning** – vedlikeholde, oppdatere og følge opp systemet.

Trusselbilde

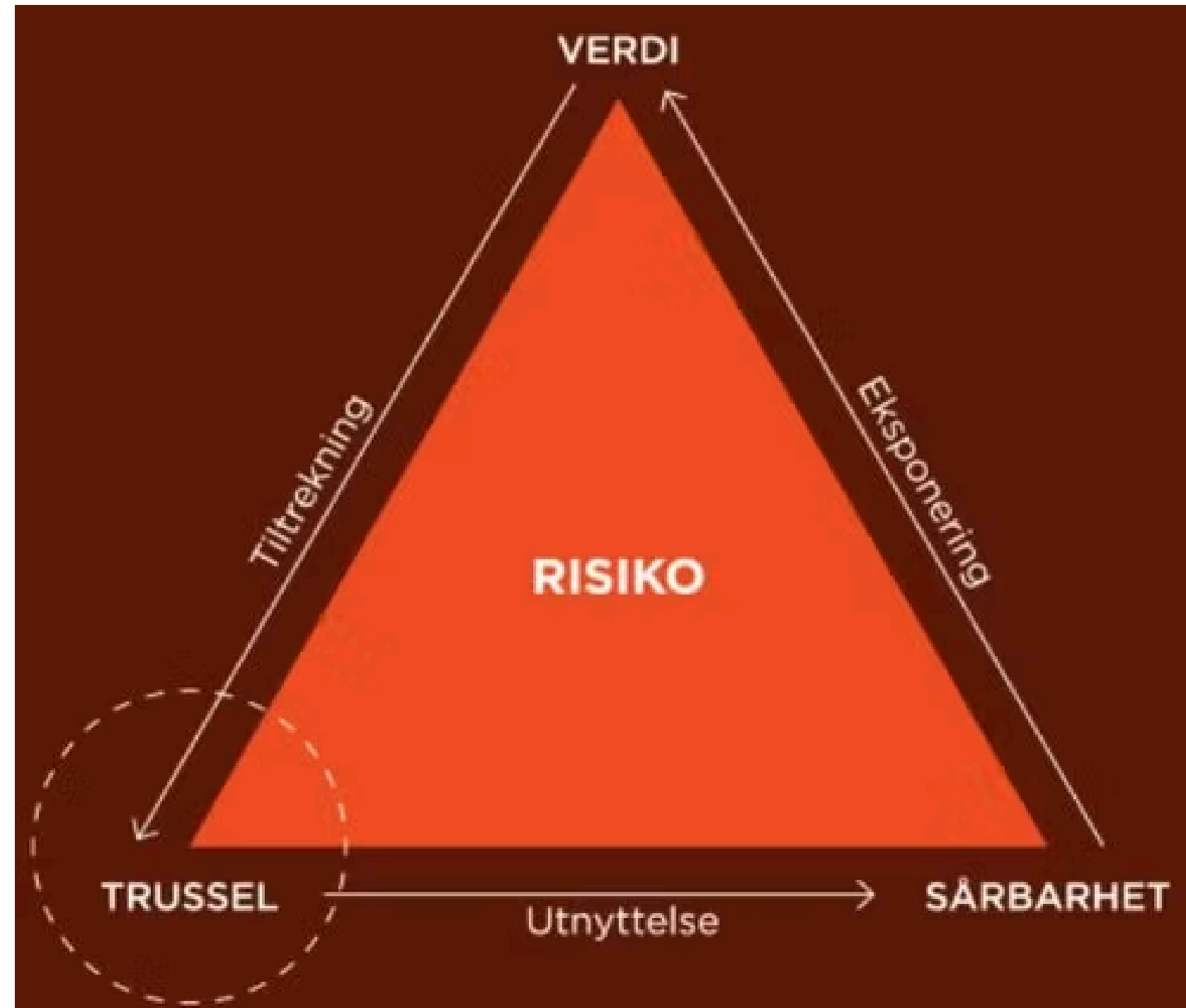
Bakteppe = **hvorfor trusselbildet er som det er**. For eksempel geopolitisk uro, økt digitalisering, avhengighet av skytjenester og organisert cyberkriminalitet.

Trender = **hvordan truslene utvikler seg over tid**. For eksempel mer bruk av KI, økt phishing, ransomware, angrep mot leverandørkjeder og utnyttelse av nye sårbarheter.

Trusselmodelling

Kan spørre følgende spørsmål:

- Hvem er gjennomfører? -> Trusselaktør
- Hva ønsker de å oppnå? -> Mål
- Hvordan gjør de det? -> Angrepsvektor
- Hva kan de angripe? -> Angrepsflate / sårbarheter



Risiko

Risikoanalyse

Sannsynlighet:

sjansen for at angrepet forkommer

Konsekvens:

kostnaden i form av penger, tap av tillit, utilgjengelighet, gebyr, juridiske konsekvenser, identitetstyveri

Svært høy Høy Moderat Lav				
	Lav	Moderat	Høy	Svært høy
	Moderat	Høy	Svært høy	Svært høy
	Moderat	Moderat	Høy	Lav Moderat Høy Svært høy
Moderat	Lav	Moderat	Moderat	Høy
	Lav	Lav	Moderat	Moderat
Lav				

Risikonivå

Hvorfor går det galt?

- sikkerhet nedprioriteres
 - dyrt
 - undervurderer kostnaden av angrep -> som å ikke ha forsikring
- evig kappløp om markede
 - første til nytt, men ikke sikkert produkt
- komplekse systemer og dårlig kompetanse
- Ikke åpenhet om feil
 - tabu/ miste tillit

Administrative sikkerhetstiltak

- **Internkontroll:** Kontrollere at lover, krav og interne regler følges.
- **Styringssystem:** Systematisk måte å planlegge, styre og forbedre sikkerhetsarbeidet på.
- **Policyer/standarder:** Overordnede regler og krav til sikkerhet.
- **Prosedyrer og praksis:** Beskriver hvordan sikkerhetsoppgaver faktisk skal utføres.
- **Bevissthetstrening/opplæring:** Lære ansatte å forstå og håndtere sikkerhetsrisiko.
- **Sikkerhetsøvelser:** Trene på realistiske hendelser og angrep.
- **Hendelseshåndtering:** Rutiner for å oppdage, rapportere, håndtere og lære av sikkerheten

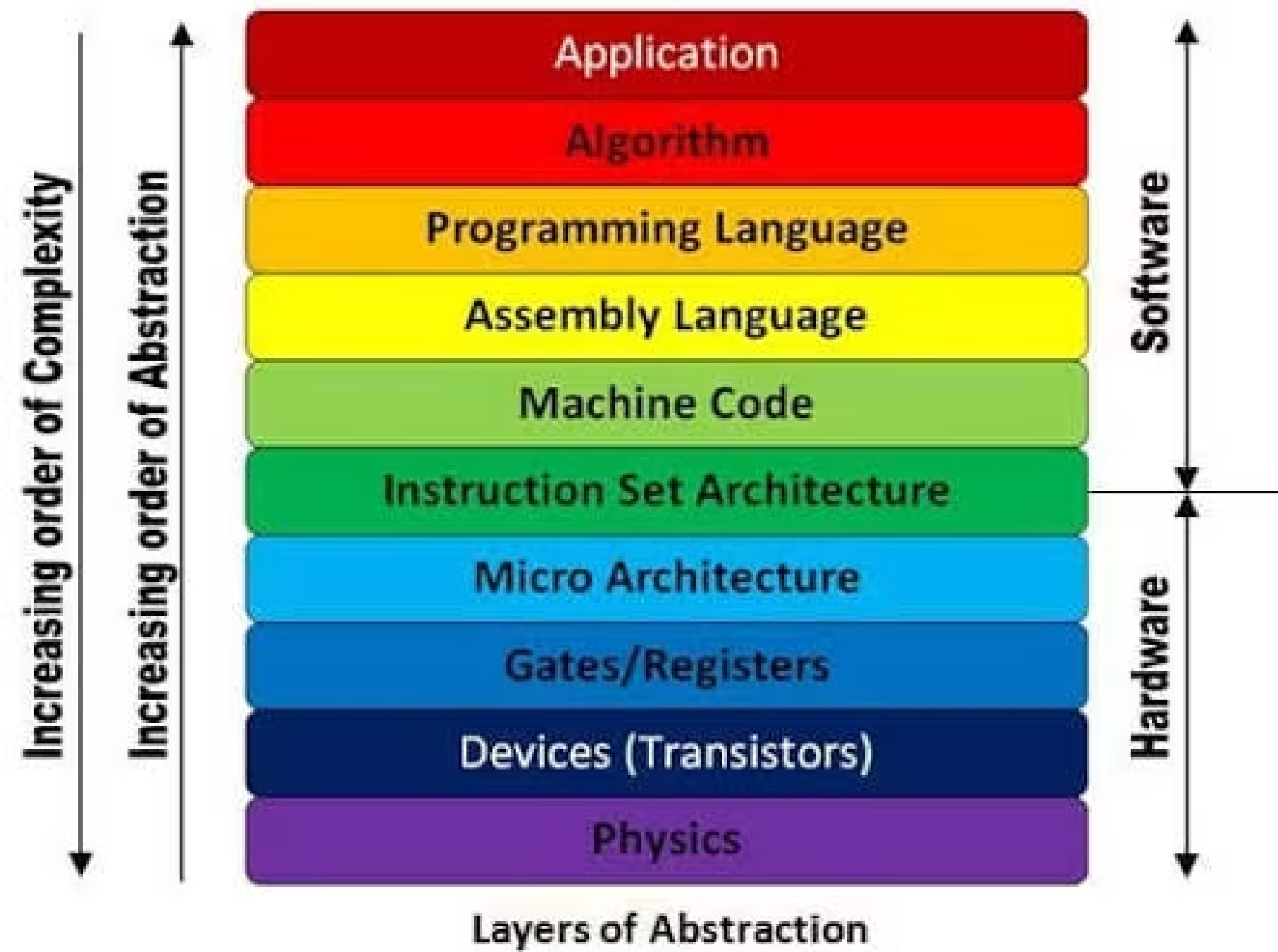
Abstraksjonsnivå

Høyt nivå → programvare

Programmer og programmeringsspråk. Mange detaljer om maskinvaren er skjult.

Lavt nivå → maskinvare

Maskinkode → CPU/instruksjoner → logiske porter → transistorer → elektriske signaler.



De ulike nivåene